Health Insurance Portability and Accountability Act (HIPAA) & Health Information Technology for Economic and Clinical Health (HITECH) Act

HIPAA and the HITECH Act overview

The Health Insurance Portability and Accountability Act of 1996 (HIPAA) and the regulations issued under HIPAA are a set of U.S. healthcare laws that establish requirements for the use, disclosure, and safeguarding of individually identifiable health information. The scope of HIPAA was extended with the enactment of the Health Information Technology for Economic and Clinical Health (HITECH) Act in 2009.

HIPAA applies to covered entities (specifically, health care providers, health plans, and health care clearinghouses) that create, receive, maintain, transmit, or access patients' protected health information (PHI). HIPAA further applies to business associates of covered entities that perform certain functions or activities involving PHI as part of providing services to the covered entity or on behalf of the covered entity.

When a covered entity engages the services of a cloud service provider, such as Microsoft, the cloud service provider is a business associate under HIPAA. Moreover, when a business associate subcontracts with a cloud service provider to create, receive, maintain, or transmit PHI, the cloud service provider also becomes a business associate.

Microsoft, HIPAA, and the HITECH Act

HIPAA regulations require that covered entities (defined under the Rules) enter into agreements with business associates to ensure that PHI is adequately protected. This agreement is called a Business Associate Agreement. Among other things, a Business Associate Agreement establishes the permitted and required uses and disclosures of PHI by the business associate, based on the relationship between the parties and the activities or services being performed by the business associate. To support our customers' compliance with HIPAA when utilizing Microsoft enterprise products and services, Microsoft enters into Business Associate Agreements with its covered entity and business associate customers.

There's currently no certification standard that the Department of Health and Human Services approves to demonstrate compliance with HIPAA or the HITECH Act by a business associate.

However, Microsoft enables customers in their compliance with HIPAA and the HITECH Act and adheres to the Security Rule requirements of HIPAA in its capacity as a business associate. Moreover, Microsoft enters into Business Associate Agreements with its covered entity and business associate customers to support their compliance with HIPAA obligations.

Third-party certifications

Microsoft services covered under the BAA undergo audits conducted by accredited independent auditors for the Microsoft ISO/IEC 27001 certification and the HITRUST Common Security Framework (CSF) certification.

Microsoft enterprise cloud services are also covered by FedRAMP assessments. Microsoft Azure and Microsoft Azure Government received a Provisional Authority to Operate from the FedRAMP Joint Authorization Board; Microsoft Dynamics 365 U.S. Government received an Agency Authority to Operate from the US Department of Housing and Urban Development, as did Microsoft Office 365 U.S. Government from the U.S. Department of Health and Human Services.

To learn how the Microsoft Cloud helps customers support HIPAA and the HITECH requirements, visit Microsoft Customer Stories .

Microsoft in-scope cloud platforms and services

- Azure and Azure Government
- Azure DevOps Services
- Dynamics 365 and Dynamics 365 U.S. Government
- Microsoft Intune
- Microsoft Copilot for Security
- Microsoft Defender for Cloud Apps
- Microsoft Defender Experts for Hunting
- Microsoft Defender Experts for XDR
- Microsoft Healthcare Bot Service
- Microsoft Managed Desktop
- Microsoft Professional Services: Premier and On Premises for Azure, Dynamics 365, Microsoft Intune, and for medium business and enterprise customers of Microsoft 365 for business
- Office 365, Office 365 U.S. Government
- Power Automate cloud service either as a standalone service or as included in an Office 365 or Dynamics 365 branded plan or suite
- Power Apps cloud service either as a standalone service or as included in an Office 365 or Dynamics 365 branded plan or suite

- Power BI cloud service either as a standalone service or as included in an Office 365 or Dynamics 365 branded plan or suite
- Windows 365

Azure, Dynamics 365, and HIPAA

For more information about Azure, Dynamics 365, and other online services compliance, see the Azure HIPAA offering.

Office 365 and HIPAA

Office 365 environments

Microsoft Office 365 is a multi-tenant hyperscale cloud platform and an integrated experience of apps and services available to customers in several regions worldwide. Most Office 365 services enable customers to specify the region where their customer data is located. Microsoft may replicate customer data to other regions within the same geographic area (for example, the United States) for data resiliency, but Microsoft will not replicate customer data outside the chosen geographic area.

This section covers the following Office 365 environments:

- **Client software (Client)**: commercial client software running on customer devices.
- **Office 365 (Commercial)**: the commercial public Office 365 cloud service available globally.
- **Office 365 Government Community Cloud (GCC)**: the Office 365 GCC cloud service is available for United States Federal, State, Local, and Tribal governments, and contractors holding or processing data on behalf of the US Government.
- **Office 365 Government Community Cloud - High (GCC High)**: the Office 365 GCC High cloud service is designed according to Department of Defense (DoD) Security Requirements Guidelines Level 4 controls and supports strictly regulated federal and defense information. This environment is used by federal agencies, the Defense Industrial Base (DIBs), and government contractors.
- **Office 365 DoD (DoD)**: the Office 365 DoD cloud service is designed according to DoD Security Requirements Guidelines Level 5 controls and supports strict federal and defense regulations. This environment is for the exclusive use by the US Department of Defense.

Use this section to help meet your compliance obligations across regulated industries and global markets. To find out which services are available in which regions, see the International availability information and the Where your Microsoft 365 customer data is stored article. For more information about Office 365 Government cloud environment, see the Office 365 Government Cloud article.

Your organization is wholly responsible for ensuring compliance with all applicable laws and regulations. Information provided in this section does not constitute legal advice and you should consult legal advisors for any questions regarding regulatory compliance for your organization.

Office 365 applicability and in-scope services

Use the following table to determine applicability for your Office 365 services and subscription:

Expand table

Applicability	In-scope services
Commercial	Access Online, Azure Communications Service, Compliance Manager, Customer Lockbox, Delve, Exchange Online, Forms, Griffin, Identity Manager, Lockbox (Torus), Microsoft Copilot, Microsoft Copilot Chat, Microsoft Defender for Office 365, Microsoft Entra ID, Microsoft Purview portal, Microsoft Teams, MyAnalytics, Office 365 Advanced Compliance add-on, Office 365 Customer Portal, Office 365 Microservices (including but not limited to ObjectStore, Sway, Power Automate, PowerPoint Online Document Service, Query Annotation Service, School Data Sync, Siphon, Speech, eXtensible Application Program), Office Online, Office Pro Plus, Office Services Infrastructure, OneDrive for Business, Planner, Power Apps, Power BI, Project Online, Service Encryption with Microsoft Purview Customer Key, SharePoint Online, Stream
GCC	Azure Communications Service, Compliance Manager, Delve, Exchange Online, Forms, Microsoft Copilot, Microsoft Copilot Chat, Microsoft Defender for Office 365, Microsoft Entra ID, Microsoft Purview portal, Microsoft Teams, MyAnalytics, Office 365 Advanced Compliance add-on, Office Online, Office Pro Plus, OneDrive for Business, Planner, Power Apps, Power Automate, Power BI, SharePoint Online, Stream

Frequently asked questions

Can my organization enter into a BAA with Microsoft?

Yes. Microsoft offers its covered entity and business associate customers a Business Associate Agreement that covers in-scope Microsoft services.

The Microsoft HIPAA Business Associate Agreement is available through the Microsoft Online Services Data Protection Addendum by default to all customers who are covered entities or business associates under HIPAA. See 'Microsoft in-scope cloud services' on this webpage for the list of cloud services covered by this BAA.

The HIPAA Business Associate Agreement is also available for in-scope Microsoft Professional Services. Contact your Microsoft services representative for more information.

Does having a Business Associate Agreement with Microsoft ensure my organization's compliance with HIPAA and the HITECH Act?

No. By offering a Business Associate Agreement, Microsoft helps support your HIPAA compliance. However, using Microsoft services doesn't on its own achieve HIPAA compliance. Your organization is responsible for ensuring that you have an adequate compliance program and internal processes in place, and that your particular use of Microsoft services aligns with your obligations under HIPAA and the HITECH Act.

Can Microsoft use my organization's Business Associate Agreement?

No, Microsoft can't use a customer's Business Associate Agreement. Because we offer hyperscale, multitenant services that are standardized for all our customers, we must operate in a consistent manner. The Microsoft HIPAA Business Associate Agreement closely reflects how we operate. Accordingly, in order to address the needs of the healthcare industry, Microsoft collaborated with a consortium of academic medical centers and other public and private sector entities within healthcare to create a Business Associate Agreement that aligns with our scale service offerings and meets the needs of customers.

How can I get copies of third party audit reports?

The Service Trust Portal provides independently audited compliance reports. You can use the portal to request audit reports so that your auditors can compare Microsoft's cloud services results with your own legal and regulatory requirements. Azure customers can also retrieve Azure certificates and audit reports in the Azure portal through the audit reports blade in Microsoft Defender for Cloud .

How can I learn more about how Microsoft supports compliance with HIPAA and the HITECH Act?

To assist customers with this task, Microsoft has published this guidance:

- HIPAA/HITECH Act implementation guidance for Azure for privacy, security, and compliance officers and others responsible for HIPAA and HITECH Act implementation, describes concrete steps your organization can take to maintain compliance.

Use Microsoft Purview Compliance Manager to assess your risk

Microsoft Purview Compliance Manager is a feature in the Microsoft Purview portal to help you understand your organization's compliance posture and take actions to help reduce risks. Compliance Manager offers a premium template for building an assessment for this regulation. Find the template in the **assessment templates** page in Compliance Manager. Learn how to build assessments in Compliance Manager.

Resources

- Microsoft HIPAA Business Associate Agreement
- Microsoft Cloud for healthcare compliance offerings
- Microsoft Cloud for the Healthcare Industry

Last updated on 07/29/2025